

SIMATS ENGINEERING
ASSESSMENT TOOL III – Penetration testing Task

Course:	Code:	CO: CO3
Duration: 90 min	Total Marks: 50	Reg No : 192372141 Name : J. Sravani

COURSE OUTCOME COVERED

***CO3:** Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities.(BL4)*

Duration: 90 min

Instructions: Answer all questions. Each question carries 10 marks.

1. An organization has commissioned an external penetration test to determine how much information an unauthorized attacker could gather about its internet-facing infrastructure without directly attacking its systems. Using the **theHarvester** tool against the authorized domain **tesla.com**, conduct a comprehensive reconnaissance exercise to identify publicly available email addresses, subdomains, hostnames, IP addresses, URLs, and other relevant infrastructure information. determine how it contributes to the external attack surface, including the risks associated with exposed employee information, unnecessary subdomains, hostnames, and externally hosted services. how multiple pieces of information could be combined by an attacker, the associated risks, recommended controls to reduce information disclosure, and which findings should be validated during subsequent penetration-testing phases. **Required Tool: theHarvester.**

Objective :

This exercise applies passive reconnaissance techniques to the authorized domain tesla.com using theHarvester, with the goal of surfacing publicly known hosts, subdomains, IP addresses, email addresses, and other infrastructure-related information.

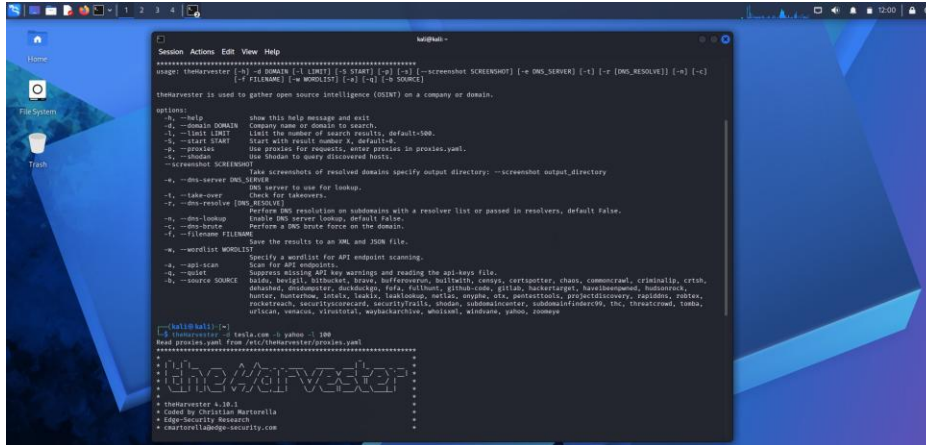
Tool Used

- **Tool:** theHarvester
- **Version:** 4.8.2
- **Target:** tesla.com
- **Type:** Passive Reconnaissance / OSINT

Command Help and Tool Options

First, theHarvester help command was used to understand the available options and search sources.

Command Used : theHarvester -h



Observation

The help menu confirms that theHarvester can gather open-source information—hosts, IP addresses, email addresses, people, and related domain data—by querying a range of configurable search sources.

Reconnaissance Using DuckDuckGo

The first data-gathering pass used DuckDuckGo as the search source, with the result count capped at 100.

Command Used : theHarvester -d tesla.com -b duckduckgo -l 100

Where:

- `-d tesla.com` : Specifies the target domain.
- `-b duckduckgo` : Uses DuckDuckGo as the search source.
- `-l 100` : Limits the number of search results.

```
Session Actions Edit View Help
(kali@kali)-[~]
└─$ theHarvester -d tesla.com -b duckduckgo -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
*****
* theHarvester 4.0.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2fdigitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

(kali@kali)-[~]
└─$ theHarvester -d tesla.com -b bing -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
*****
* theHarvester 4.0.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
```

Observation

The DuckDuckGo query returned 4 host entries:

1. 2fdigitalassets.tesla.com
2. 2fir.tesla.com
3. digitalassets.tesla.com
4. ir.tesla.com

Reconnaissance Using Bing

A follow-up query was run against Bing to compare coverage with the DuckDuckGo results.

Command Used : theHarvester -d tesla.com -b bing -l 100

```
Session Actions Edit View Help
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 1
shop.tesla.com

(kali@kali)-[~]
└─$ theHarvester -d tesla.com -b crtsh -l 100
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
*****
* theHarvester 4.0.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****

[*] Target: tesla.com
An exception has occurred: 502, message='Attempt to decode 350W with unexpected mimetype: text/html', url='https://crt.sh/?q=k23.tesla.com&exclude-expired&deduplicate=y&output=json'
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

Observation

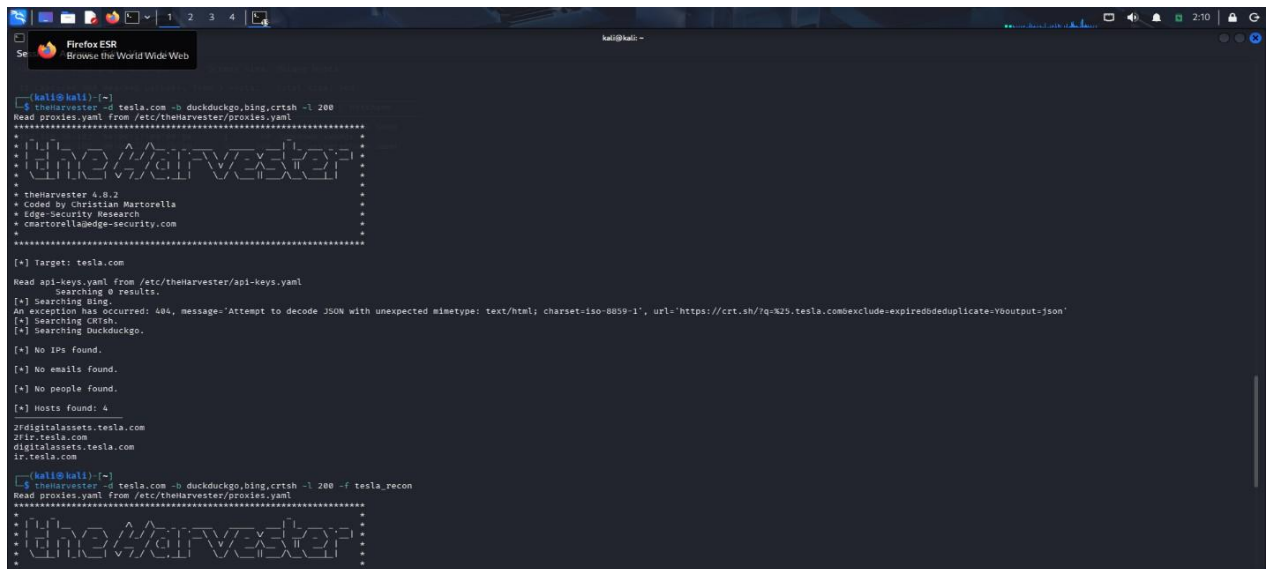
- Bing returned a single host record: shop.tesla.com
- No IP addresses, email addresses, or people were surfaced by this source.

Combined Search Using Multiple Sources

To widen the coverage of the passive reconnaissance, several sources were queried in the same run.

Commands Used :

- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
- theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon



```
(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
Read proxies.yaml from /etc/theHarvester/proxies.yaml

*****
theHarvester
*****
theHarvester 4.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorell@edge-security.com
*****

[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.
An exception has occurred: 404, message='Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1', url='https://crt.sh/?q=K25.tesla.com&exclude-expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] Searching Duckduckgo.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2digitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon
Read proxies.yaml from /etc/theHarvester/proxies.yaml

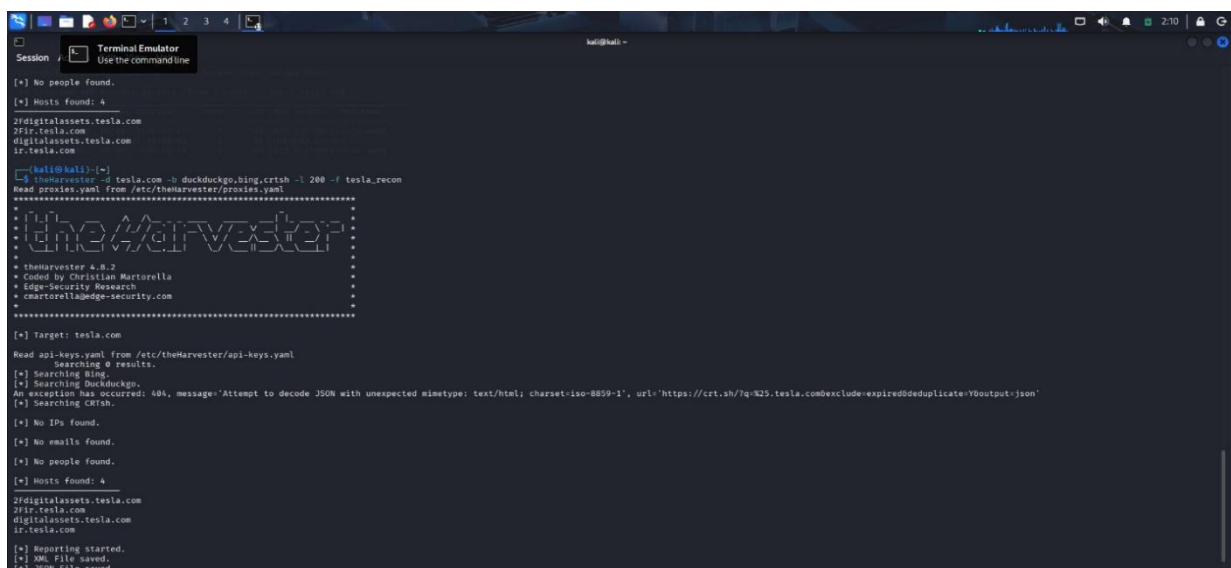
*****
theHarvester
*****
theHarvester 4.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorell@edge-security.com
*****

[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.
An exception has occurred: 404, message='Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1', url='https://crt.sh/?q=K25.tesla.com&exclude-expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2digitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

[*] Reporting started.
[*] HTML File saved.
[*] JSON File saved.
```

Results of the multi-source query:

- IPs found: 0
- Emails found: 0
- People found: 0
- Hosts found: 4



```
(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200
Read proxies.yaml from /etc/theHarvester/proxies.yaml

*****
theHarvester
*****
theHarvester 4.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorell@edge-security.com
*****

[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.
An exception has occurred: 404, message='Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1', url='https://crt.sh/?q=K25.tesla.com&exclude-expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2digitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

(kali@kali)~$ theHarvester -d tesla.com -b duckduckgo,bing,crtsh -l 200 -f tesla_recon
Read proxies.yaml from /etc/theHarvester/proxies.yaml

*****
theHarvester
*****
theHarvester 4.0.2
Coded by Christian Martorella
Edge-Security Research
cmartorell@edge-security.com
*****

[*] Target: tesla.com
Read api-keys.yaml from /etc/theHarvester/api-keys.yaml
Searching 0 results.
[*] Searching Bing.
An exception has occurred: 404, message='Attempt to decode JSON with unexpected mimetype: text/html; charset=iso-8859-1', url='https://crt.sh/?q=K25.tesla.com&exclude-expired&deduplicate=Y&output=json'
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 4
2digitalassets.tesla.com
2fir.tesla.com
digitalassets.tesla.com
ir.tesla.com

[*] Reporting started.
[*] HTML File saved.
[*] JSON File saved.
```

Security Analysis

- Across the DuckDuckGo and Bing runs, 5 distinct hostnames were surfaced in total.
- None of the selected sources returned IP addresses or email addresses.
- No employee-identifying information was disclosed during this reconnaissance pass.
- Discovering a host does not by itself confirm that it is vulnerable — it only flags it for further investigation.
- crt.sh could not be queried successfully; the source returned HTTP errors during the run.

Risk and Recommendations

- Remove subdomains and hosts that are no longer in active use.
- Keep a current inventory of all externally facing assets.
- Periodically review which hostnames remain publicly resolvable.
- Limit the amount of information the organization exposes publicly by default.
- Verify externally reachable services as part of authorized security testing cycles.

Conclusion

theHarvester was used successfully to gather passive OSINT on tesla.com, surfacing 5 publicly resolvable hostnames across the queried sources. No email addresses, IP addresses, or personal names were returned.

crt.sh could not be reached successfully and returned HTTP errors, so it contributed no usable data. Full results from the other sources were exported in both XML and JSON for later reference.

- During a penetration-testing engagement, assess the publicly accessible web application **testphp.vulnweb.com** using the **Nikto** tool to identify potentially exposed files and directories, insecure HTTP methods, server configuration weaknesses, information-disclosure issues, outdated components, dangerous files, and other potential security weaknesses. For every significant finding, collect appropriate evidence and determine whether it represents a confirmed vulnerability, a configuration weakness, or an issue requiring further manual validation. Prepare a final assessment including the commands used, significant findings, supporting evidence, potential security impact, likelihood of exploitation, recommended remediation measures, methods for validating remediation, and a prioritized list of the most important findings, with particular attention to exposed files, server-version information, directory listings, insecure HTTP methods, and outdated components. **Required Tool: Nikto.**

Objective:

This assessment uses Nikto against an authorized, intentionally vulnerable web server to surface outdated software, disclosed information, missing security headers, and other configuration weaknesses.

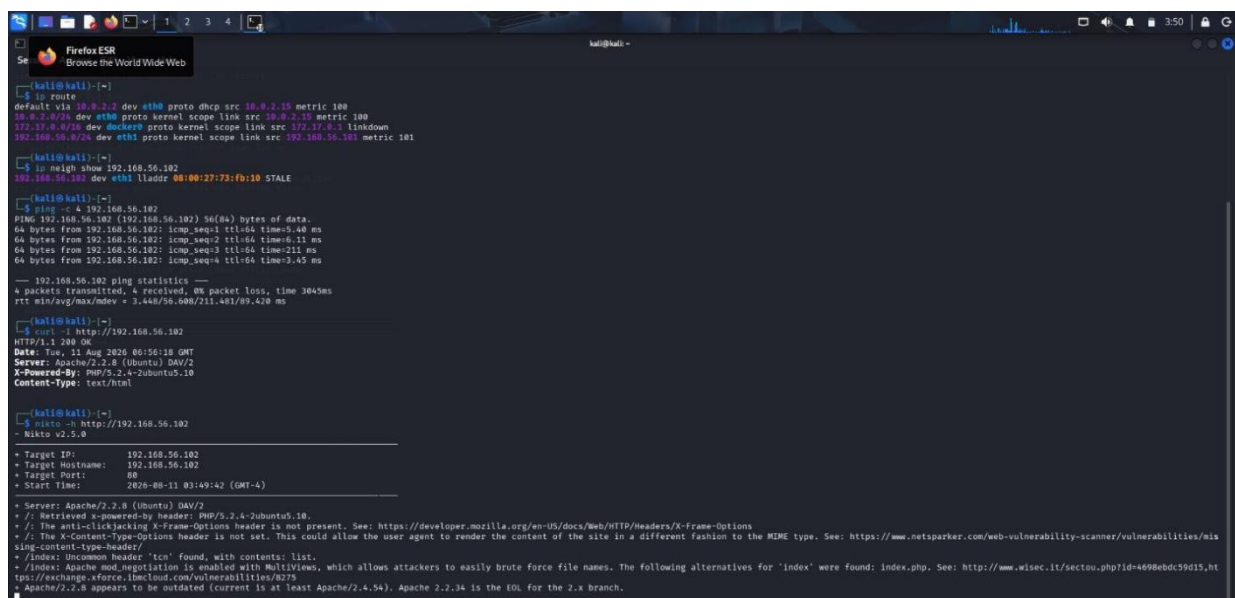
Target: 192.168.56.102 - Metasploitable 2

Tool: Nikto 2.5.0

Protocol: HTTP/80

Commands Used

- `ping -c 4 192.168.56.102`
- `curl -I http://192.168.56.102`
- `nikto -h http://192.168.56.102`



```
kali@kali:~$ ip route
default via 10.0.2.3 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100
172.17.0.0/16 dev docker0 proto kernel scope link src 172.17.0.1 linkdown
192.168.56.0/24 dev eth1 proto kernel scope link src 192.168.56.101 metric 101

kali@kali:~$ ip neigh show 192.168.56.102
192.168.56.102 dev eth1 lladdr 08:00:27:73:fb:10 STALE

kali@kali:~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(64) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=5.40 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=6.11 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=211 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=3.45 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3045ms
rtt min/avg/max/mdev = 3.448/56.080/211.481/89.420 ms

kali@kali:~$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Tue, 11 Aug 2020 05:56:18 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Content-Type: text/html

kali@kali:~$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2020-08-11 03:49:42 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The x-clickjacking x-frame-options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /index: Unknown header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4998ebdc59d15,ht-tps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.34), Apache 2.2.34 is the EOL for the 2.x branch.
```

```

    inet addr:192.168.56.102 Bcast:192.168.56.255 Mask:255.255.255.0
    inet6 addr: fe80::a00:27ff:fe73:fb10/64 Scope:Link
    UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
    RX packets:2148 errors:0 dropped:0 overruns:0 frame:0
    TX packets:1268 errors:0 dropped:0 overruns:0 carrier:0
    collisions:0 txqueuelen:1000
    RX bytes:177874 (173.7 KB) TX bytes:92200 (90.0 KB)
    Base address:0xd020 Memory:f0200000-f0220000

msfadmin@metasploitable:~$ ping -c 192.168.56.101
Usage: ping [-LRUbdfngrvUaA] [-c count] [-i interval] [-w deadline]
          [-p pattern] [-s packetsize] [-t ttl] [-I interface or address]
          [-M mtu discovery hint] [-S sndbuf]
          [-T timestamp option] [-Q tos] [hop1 ...] destination
msfadmin@metasploitable:~$ ping -c 4 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=2.20 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=1.41 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=245 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=1.99 ms

--- 192.168.56.101 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3002ms
rtt min/avg/max/mdev = 1.410/62.830/245.713/105.587 ms
msfadmin@metasploitable:~$

```

Findings

- Apache/2.2.8 detected - outdated component (High).
- PHP/5.2.4 detected - outdated component (High).
- Apache and PHP versions are disclosed (Medium).
- X-Frame Options is missing (Medium).
- X-Content Type Options is missing (Low - Medium).
- Apache MultiViews is enabled (Medium).
- Uncommon tcn header detected (Manual validation required).

Recommendations

Recommended remediation: update Apache and PHP to supported versions, suppress unnecessary version banners, add the missing security headers, turn off MultiViews unless it is required, and look into the flagged tcn header. A follow-up Nikto scan should confirm the fixes took effect.

Conclusion:

Nikto surfaced several weaknesses on the authorized Metasploitable server, with the outdated Apache and PHP versions standing out as the top-priority items to remediate.

3. A company is conducting an external security assessment to determine whether its DNS infrastructure discloses more information than intended. Using the **Dig** utility against the authorized target domain **zonetransfer.me**, perform a detailed DNS enumeration exercise by identifying and documenting the available A, AAAA, MX, NS, CNAME, TXT, SOA, and other relevant DNS records, determining the authoritative servers, and assessing whether an unauthorized DNS zone transfer can be requested. Analyze the results from an attacker's perspective and explain how DNS records can reveal mail infrastructure, server naming conventions, hostnames, service relationships, and other infrastructure information. Your assessment should identify the DNS records and authoritative servers, determine whether a zone transfer was possible, explain the additional information exposed by a successful zone transfer and the risks of unrestricted AXFR access, discuss how DNS information can be combined with other reconnaissance techniques, recommend appropriate DNS security controls, and explain how remediation can be verified. **Required Tool: Dig.**

Objective

This step enumerates the DNS records for the authorized domain zonetransfer.me using dig, identifies its authoritative name servers, and checks whether an unauthorized zone transfer (AXFR) can be performed.

Tool Used

Tool : Dig

Target : zonetransfer.me

Platform : Kali Linux

Procedure

1. The following record types were queried:

- dig zonetransfer.me
- dig zonetransfer.me NS
- dig zonetransfer.me SOA
- dig zonetransfer.me A
- dig zonetransfer.me AAAA
- dig zonetransfer.me MX
- dig zonetransfer.me CNAME
- dig zonetransfer.me TXT

Results

1. Zone transfer succeeded against both authoritative name servers:
 - nsztml.digi.ninja
 - nsztml2.digi.ninja
2. Both servers returned the full zone on request — 52 DNS records from the first server and 52 from the second.

Security Analysis

Because the transfer succeeded, an outside party could pull the entire zone in one request. That data can expose:

- Server IP addresses
- Mail infrastructure
- Host naming conventions
- VPN-related hosts
- Office infrastructure
- Internal DNS names.

Recommendations

- Limit AXFR/IXFR requests to approved secondary DNS servers only.
- Require TSIG (or an equivalent mechanism) to authenticate zone-transfer requests.
- Block zone-transfer requests originating from unauthorized external hosts.
- Keep internal and external DNS data logically separated.
- Clean up DNS records that are outdated or no longer needed.
- Log and alert on unexpected AXFR attempts.

Conclusion

Both authoritative servers for zonetransfer.me permitted an unrestricted zone transfer, each releasing 52 records covering hostnames, IP addresses, mail infrastructure, and other service details. This confirms the reconnaissance value an attacker could gain from unrestricted AXFR and underlines why zone-transfer access should be limited to trusted DNS infrastructure only.

4. As part of an internal penetration-testing engagement, assess the authorized Windows/SMB target **192.168.1.100** using **Enum4linux** to determine what information could be obtained through SMB and NetBIOS enumeration before attempting exploitation. Perform comprehensive enumeration to identify available users, groups, shared resources, domain or workgroup information, operating-system details, password-policy information, NetBIOS information, and other exposed SMB configuration details permitted by the target. Analyze the collected information from an attacker's perspective and determine whether it could facilitate credential attacks, privilege escalation, unauthorized access to shared resources, vulnerability identification, or lateral movement. Prepare a report containing the commands used, identified users and groups, discovered shared resources, relevant system and domain information, evidence of anonymous or null-session enumeration, security implications, relationships between accounts, groups and privileges, risks of unnecessarily accessible SMB shares, recommended controls, and a prioritized remediation plan covering SMB configuration, access control, authentication, patching, and network segmentation.

Required Tool: Enum4linux.

Objective :

This step performs authorized SMB/NetBIOS enumeration of a Windows target with Enum4linux to determine what users, groups, shares, workgroup data, NetBIOS details, and password-policy information the host discloses.

Target and Tools

Target : 192.168.56.102

Tester : Kali Linux

Required tool : Enum4linux v0.9.1

Supporting tools : Nmap, smbclient

Network : Isolated VirtualBox Host-Only network

Commands Used

- nmap -Pn -p 139,445 192.168.56.102
- enum4linux -a 192.168.56.102
- enum4linux -U 192.168.56.102
- enum4linux -G 192.168.56.102
- enum4linux -S 192.168.56.102

The image contains two terminal screenshots. The left screenshot shows an Nmap scan of 192.168.56.102, identifying open ports 139/tcp (netbios-ssn) and 445/tcp (microsoft-ds). It also shows the output of enum4linux v0.9.1, which enumerates the target's NetBIOS information, including RID range (500-558, 1000-1050), username, password, and known usernames (administrator, guest, krbtgt, domain admins, root, bin, none). The right screenshot shows a session check on 192.168.56.102 using enum4linux, which fails to connect with SMB1 due to an error (NT_STATUS_RESOURCE_NAME_NOT_FOUND) and reports that the server doesn't allow sessions using an empty username and password.

SMB Port Findings

1. Nmap identified :

- 139/tcp OPEN netbios-ssn
- 445/tcp OPEN microsoft-ds

2. Workgroup and NetBIOS Findings

Enum4linux returned the following NetBIOS service entries:

- <20> - File Server Service
- <00> - Workstation Service

This information was obtained directly through NetBIOS enumeration.

3. Anonymous/Null-Session Testing

Enum4linux tried to open an unauthenticated (null) session using a blank username and password. The target refused the attempt:

- Server doesn't allow session using username "", password "".
- The same block also stopped anonymous enumeration of users, groups, and shares.
- Conclusion: null-session enumeration was not permitted against this host.

4. Authenticated SMB Share Enumeration

- Once authenticated with a valid Windows account, the following shares became visible:
- This share listing was only obtainable after successful authentication — it was not accessible anonymously.

5. Windows Account Findings

- Local accounts discovered on the target: Administrator and DefaultAccount.
- Because Administrator carries elevated rights, compromising that account's credentials would give an attacker full administrative control of the host.

Security Analysis

- Viewed from an attacker's standpoint, this enumeration data is useful reconnaissance for several reasons:
- The presence of SMB flags the host as a Windows system that shares files over the network.
- NetBIOS and workgroup details help place the host within its network context.
- Disclosed local account names give an attacker a ready list of usernames to target.
- Identifying which accounts belong to the administrative group highlights the highest-value credentials.
- If credentials are ever compromised, the administrative shares become a direct path to further access.
- A weak password policy would make credential-based attacks against these accounts more likely to succeed.

Recommendations

- Limit SMB exposure with host- and network-level firewall rules.
- Turn off SMB services that aren't required, including legacy SMB1.
- Keep share and NTFS permissions tightly scoped.
- Audit local administrator group membership and drop accounts that don't need it.
- Set a strong minimum password length.
- Turn on an appropriate password-history policy.

Conclusion

This engagement confirmed SMB and NetBIOS enumeration against the authorized Windows host: ports 139 and 445 were reachable, and enumeration surfaced the WORKGROUP name, a JAHNAVI-related entry, and the standard administrative shares. Anonymous/null-session access was properly refused, but authenticated enumeration still exposed administrative shares and confirmed a privileged local account. Priority remediation areas are stronger password controls, least-privilege account management, tighter SMB exposure, and ongoing patching.

5. During an external penetration-testing engagement, assess the authorized target **scanme.nmap.org** using **Netcat (nc)** to connect to accessible TCP services and collect service responses and banner information. Analyze the responses to determine what technical information the target voluntarily discloses, including service type, protocol, software name, version information, HTTP response headers, operating-system clues, and other implementation details. For each significant observation, explain what information was disclosed, which service provided it, how it could assist an attacker with fingerprinting, whether version information could be correlated with known vulnerabilities, whether the finding represents a vulnerability or merely information disclosure, what additional validation is required, and what remediation measures could reduce unnecessary exposure. Finally, explain how the organization should monitor and periodically reassess externally exposed services and discuss the security implications of service-banner exposure and how accurate service fingerprinting can make subsequent attacks more targeted. **Required Tool: Netcat (nc).**

Netcat External Service Assessment

Objective :

This step uses Netcat against the authorized target scanme.nmap.org to connect to open TCP services and capture whatever banners or responses they return, then evaluates what that disclosed information means from a security standpoint.

Domain: scanme.nmap.org

IP: 45.33.32.156

Tool: Netcat (nc)

Platform: Kali Linux

Commands Used

- ping -c 4 scanme.nmap.org
- nc -vz scanme.nmap.org 22
- nc -v 45.33.32.156 22
- nc -vz scanme.nmap.org 80
- nc -v 45.33.32.156 80
- nc -vz scanme.nmap.org 53
- nc -vz scanme.nmap.org 9929
- nc -v 45.33.32.156 9929


```
Session Actions Edit View Help
Terminal Emulator
Use the command line

kali@kali:~$ cat /dev/null > .zsh_history

kali@kali:~$ [v1.10-50.1]
connect to somewhere: nc [-options] hostname port[s] [ports] ...
listen or inbound: nc -l [-p port] [-options] [hostname] [port]
options:
-c shell commands          as -e: use /bin/sh to exec [dangerous!!]
-e filename                program to exec after connect [dangerous!!]
-a allow broadcasts        allow broadcasts
-s source-routing hop point[s], up to 8    source-routing hop point[s], up to 8
-g num                     source-routing pointer: 4, 8, 12, ...
-t this scruff             this scruff
-i secs                    delay interval for lines sent, ports scanned
-l                          listen mode, for inbound connects
-n numeric-only IP addresses, no DNS    numeric-only IP addresses, no DNS
-o file                    hex dump of traffic
-p port                    local port number
-r randomize local and remote ports    randomize local and remote ports
-q secs                    quit after EOF on stdin and delay of secs
-a addr                    local source address
-T tos                      set Type Of Service
-u                          answer TELNET negotiation
-W secs                    UDP mode
-w                          verbose [use twice to be more verbose]
-x                          timeout for connects and final net reads
-z                          Send CRLF as line-ending
-Z zero-I/O mode [used for scanning]
-l0-hl [inclusive];
port numbers can be individual or ranges: lo-hi [inclusive];
hyphens in port names must be backslash escaped (e.g. 'ftp-data').

kali@kali:~$ ping -c 4 scanme.nmap.org
PING scanme.nmap.org (45.33.32.156) 56(84) bytes of data:
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=1 ttl=255 time=474 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=2 ttl=255 time=406 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=3 ttl=255 time=414 ms
64 bytes from scanme.nmap.org (45.33.32.156): icmp_seq=4 ttl=255 time=338 ms

--- scanme.nmap.org ping statistics ---
4 packets transmitted: 4 received, 0% packet loss, time 4120ms
rtt min/avg/max/mdev = 338.003/406.143/474.295/46.320 ms

kali@kali:~$ nc -vz scanme.nmap.org 22
scanme.nmap.org [45.33.32.156] 22 (ssh) open

kali@kali:~$ nc -nv scanme.nmap.org 22
Can't parse scanme.nmap.org as an IP address
```

```
Session Actions Edit View Help

kali@kali:~$ nc -v 45.33.32.156 22
scanme.nmap.org [45.33.32.156] 22 (ssh) open
SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
^C

kali@kali:~$ nc -v scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

kali@kali:~$ nc -vz scanme.nmap.org 80
scanme.nmap.org [45.33.32.156] 80 (http) open

kali@kali:~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
GET / HTTP/1.1
Host: scanme.nmap.org
Connection: close
Date: Wed, 12 Aug 2020 05:23:15 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>
</body></html>

kali@kali:~$ Connection: close
Connection:: command not found

kali@kali:~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
HEAD / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Wed, 12 Aug 2020 05:24:23 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Connection: close
Content-Type: text/html; charset=iso-8859-1
```

```
kali@kali:~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
HEAD / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Wed, 12 Aug 2020 05:24:23 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>
</body></html>

kali@kali:~$ Connection: close
Connection:: command not found

kali@kali:~$ nc -v 45.33.32.156 80
scanme.nmap.org [45.33.32.156] 80 (http) open
HEAD / HTTP/1.1
HTTP/1.1 400 Bad Request
Date: Wed, 12 Aug 2020 05:24:23 GMT
Server: Apache/2.4.7 (Ubuntu)
Content-Length: 306
Connection: close
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>400 Bad Request</title>
</head><body>
<h1>Bad Request</h1>
<p>Your browser sent a request that this server could not understand.<br />
</p>
<hr>
<address>Apache/2.4.7 (Ubuntu) Server at scanme.nmap.org Port 80</address>
</body></html>

kali@kali:~$ nc -vz scanme.nmap.org 53
scanme.nmap.org [45.33.32.156] 53 (domain) : Connection refused

kali@kali:~$ nc -vz scanme.nmap.org 9929
scanme.nmap.org [45.33.32.156] 9929 (?) open

kali@kali:~$ nc -v 45.33.32.156 9929
scanme.nmap.org [45.33.32.156] 9929 (?) open
[crj] ++k+;Hl+5++2U/+++5!z+::[0+0sb+g+***,***mcn!q+!!-++q+K"C

kali@kali:~$
```

Observations

- Target IP: 45.33.32.156
- Ping: 4/4 received, 0% packet loss
- 22/TCP: Open - SSH
- SSH banner returned: OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
- 80/TCP: Open - HTTP
- HTTP banner returned: Apache/2.4.7 (Ubuntu)
- 53/TCP: Connection refused
- 9929/TCP: Open - binary response, service not identified

Banner:

SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13

The banner discloses the SSH protocol version, the OpenSSH build, and the underlying Ubuntu platform — useful for an attacker doing fingerprinting or vulnerability research. On its own this is only information disclosure, not confirmation of a vulnerability; the actual patch level would need to be verified separately.

HTTP Finding :

The HTTP response included:

- HTTP/1.1 400 Bad Request
- Server: Apache/2.4.7 (Ubuntu)
- Content-Type: text/html; charset=iso-8859-1
- Both the Apache version and the Ubuntu platform are disclosed here, which again supports fingerprinting and vulnerability lookups. The 400 status code itself is not a security issue.

TCP/9929

- The port was reachable and returned binary, non-printable data. Netcat alone couldn't determine what service was running, so this needs further authorized checking.

Remediation

- Keep internet-facing software up to date.
- Turn off services that don't need to be exposed.

- Restrict SSH access wherever feasible.
- Reduce the amount of version and banner information services reveal.
- Keep monitoring which ports are reachable from outside.
- Reassess the external attack surface on a regular schedule.

Conclusion

Netcat was able to reach and fingerprint the open TCP services on the target, and both SSH and HTTP returned version information useful for attacker profiling. These results are best treated as information disclosure rather than confirmed vulnerabilities, pending further validation.

Code of Conduct:

I J Sravani - 192372141 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student – J Sravani

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Task	20				
Procedure & Execution	25				
Observation & Result	20				
Viva Voce / Conceptual Response	20				
Time Management & Presentation	15				

Criteria	Understanding of Task	Procedure & Execution	Observation & Result	Viva Voce / Conceptual Response	Time Management & Presentation
Weightage	20 (2)	25 (3)	20 (2)	20 (2)	15 (1)
Q1					
Q2					
Q3					
Q4					
Q5					